

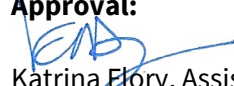


DAS Policy

No:
2100-22

Information Security Program Management

Effective:
March 5, 2024

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

This policy outlines the necessary components of a successful information security program. Effective adoption and implementation of the components outlined in this policy will provide the Ohio Department of Administrative Services (DAS) with a solid foundation on which to build the state's information security program.

The first occurrence of a defined term in the policy is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards in Technology (NIST) Special Publication (SP) 800-53 family identifiers and control numbers are provided in parentheses next to requirement headers, where applicable.

II. Scope

The scope of this policy includes ***DAS-Managed Information Systems and Services***, ***DAS-Managed System Assets***, and the DAS system and ***Service Owners*** who maintain them.

III. Policy

DAS is issuing this policy to protect DAS-Managed Information Systems and Services as well as DAS-Managed System Assets. DAS system and Service Owners, as well as the DAS Office of Information Security and Privacy (OISP), shall work together to ensure that appropriate security controls are implemented.

- A. **Senior Information Security Officer (PM-2)**: The DAS Office of Information Technology (OIT) chief information security officer (CISO), appointed in accordance with Ohio Revised Code Section 125.18 (B)(6), shall serve as the senior information security officer for the state. The

CISO shall have the mission and resources to coordinate, develop, implement, and maintain a statewide information security program.

- B. **Information Security Resources (PM-3):** Operating budget and capital budget requests shall include the resources needed to implement the information security program, to the extent feasible, given budgetary constraints.

Business cases to employ the security resources shall be documented; and information security resources shall be available for expenditure as planned.

- C. **Remediation Plan (PM-4):** DAS OISP shall implement a process for ensuring that remediation plans for the security program and associated information systems are developed and maintained.

1. Remedial information security actions shall be documented to adequately respond to the **Risk** to operations and assets, individuals, and other organizations, as necessary.
2. Remediation plans shall be reviewed for consistency with DAS Risk management strategy and statewide priorities for Risk response actions.

- D. **Information System Inventory (PM-5):** An inventory of DAS-Managed Information Systems and Services shall be developed and maintained by DAS OISP.

1. The inventory shall be updated no less than annually.
2. The inventory shall track elements such as system owner, data owner, contact information, platform basics (operating system, database, cloud, on-premises), vendor information (if any), and Risk and data classification.
3. DAS-managed information system and Service Owners are responsible for providing this information to DAS OISP.

- E. **Information Security Performance Measures (PM-6):** DAS OISP shall develop, monitor, and report on the results of information security performance measures.

- F. **Enterprise IT Security Architecture (PM-7):** DAS OISP shall develop an enterprise IT security architecture, with consideration for information security and the resulting Risk to DAS operations, assets, individuals, and other organizations. The DAS OIT Investment and Governance Division shall provide IT strategy, policy, and standards development support for enterprise IT security architecture efforts.

- G. **Critical Infrastructure Plan (PM-8):** Upon request, DAS OISP shall work with the Ohio Department of Public Safety Homeland Security on the development of a protection plan for DAS-Managed Information Systems and Services and DAS-Managed System Assets identified as **critical infrastructure** and **Key Resources**.

- H. **Risk Management Strategy (PM-9)**: DAS OISP shall develop a comprehensive Risk management strategy associated with the operation and use of DAS-managed information systems, which addresses Risk to DAS operations and assets, individuals, and other organizations.

The Risk management strategy shall be implemented consistently across DAS. The strategy shall be updated annually, or as required, to address organizational changes.

- I. **Security Authorization Process (PM-10)**: DAS OISP shall manage the security state of DAS-managed information systems, and the environments in which those systems operate, through a security authorization process as outlined in DAS Policy 2100-19, "Security Assessment and Authorization."
1. Individuals shall be designated to fulfill specific roles and responsibilities within the Risk management process.
 2. The security authorization process shall be fully integrated into a DAS-wide Risk management program.

- J. **Mission/Business Process Definition (PM-11)**: Through adherence to DAS policies 2100-04, "Data Classification," 2100-08, "Risk Assessment," and 2100-19, "Security Assessment and Authorization," DAS divisions shall define their mission and business processes with consideration for information security and the possible Risks to DAS operations, assets, individuals, and other organizations.

If information security protection needs arise, DAS divisions shall work with DAS OISP to modify their mission and business processes, as necessary, to achieve the necessary level of protection.

- K. **Insider Threat Program (PM-12)**: DAS OISP shall implement an insider threat program that includes a cross-discipline insider threat ***Incident Handling*** team.
- L. **Information Security Workforce (PM-13)**: DAS OISP shall establish an information security workforce development and improvement program.
- M. **Testing, Training, and Monitoring (PM-14)**: DAS OISP plans for conducting security testing, training, and monitoring activities associated with DAS-managed information systems shall be implemented and routinely executed in a timely manner.

Testing, training and monitoring plans shall be reviewed for consistency with the DAS Risk management strategy and statewide priorities for Risk response actions.

- N. **Security Group and Association Contacts (PM-15):** DAS OISP shall establish and institutionalize contact with selected groups and associations within the information security community.

The resources provided by these groups shall be leveraged to facilitate ongoing security education and training for organizational personnel; maintain currency with recommended security practices, techniques, and technologies; and share current, security-related information, including threats, vulnerabilities, and incidents.

- O. **Threat Awareness Program (PM-16):** DAS OISP shall implement a threat awareness program that includes a cross-organizational information-sharing capability.

IV. Definitions

- A. Critical Infrastructure. System and assets, whether physical or virtual, so vital to the United States that the incapacity or destruction of such systems and assets would have a debilitating impact on security, national economic security, national public health or safety, or any combination of those matters.¹
- B. DAS-Managed Information Systems and Services: A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information.² This includes internal DAS information systems as well as information systems and infrastructure (services) operated or managed by DAS for customer agencies. For the purposes of this policy, primary responsibility for managing these systems or services may be assigned to DAS OIT personnel or other outside entities.
- C. DAS-Managed System Asset: Information, hardware, software and services required to support state business, and identified during the Risk assessment process as assets that need to be protected. Primary responsibility for managing these system assets may be assigned to DAS OIT personnel or other outside entities.
- D. Incident Handling. The mitigation of violations of security policies and recommended practices.³
- E. Key Resources. Publicly or privately controlled resources essential to the minimal operations

¹ “NIST SP 800-30 Revision 1, Guide for Conducting Risk Assessments,” U.S. Department of Commerce National Institute of Standards and Technology, September 2012 <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>>.

² “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

³ Cichonski, Paul, Tom Millar, Tim Grance, Karen Scarfone, “National Institute of Standards and Technology Special Publication 800-61 Rev. 2 Computer Security Incident Handling Guide,” U.S. Department of Commerce National Institute of Standards and Technology, August, 2012 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>>.

of the economy and government.⁴

- F. Risk. A measure of the extent to which an entity is threatened by a potential circumstance or event, and typically a function of: (i) the adverse impacts that would arise if the circumstance or event occurs; and (ii) the likelihood of occurrence.⁵
- G. Service Owner. A Service Owner is responsible for the delivery (design, performance, integration), continual improvement and management of assigned IT services.

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-04 Data Classification	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-08 Risk Assessment	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-19, Security Assessment and Authorization	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services

⁴ Homeland Security Act of 2002 (Section 2(9)): Public Law 107-296, 107th Congress, H.R. 5005, November 25, 2002. <https://www.dhs.gov/sites/default/files/publications/hr_5005_enr.pdf>.

⁵ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
01/19/2021	Original Policy.
08/02/2021	Conducted routine maintenance review of citations and references.
03/05/2024	Updated organizational references to align with the current structure. Updated the policy template. Added a revision history review frequency statement.